Detecting Harmful LLM-Agent Commands in Industrial IoT with Task-Aware Graph Neural Networks

Repérer les ordres nuisibles d'un agent LLM en usine par un graphe

---

B. Mokhtari, Y. Ameur, S. Bouzefrane

Présentation du mardi 27/10

IEEE IoT Journal, numéro spécial « Graph Representation Learning for IoT » – dépôt le 30/11/2026

Le problème en une phrase

Un agent LLM détourné peut envoyer à un automate une commande **valide, autorisée et banale**, mais **au mauvais moment**.

Exemple dans l'usine de batteries :

- L'agent écrit « vitesse d'enduction = 12 m/min ».
- Pendant l'enduction stable : routine.
- Pendant la chauffe du sécheur : couche mal séchée, lot perdu.
- Même outil, même registre, même valeur : seul le **contexte** change.
- On appelle cela une commande **« context-shifted »**.

Pourquoi maintenant ?

- Des agents LLM pilotent déjà des cellules de production en prototype.
  [Xia et al., ETFA 2025 ; Vyas & Mercangöz, arXiv 2025]
- L'injection indirecte de consignes marche contre des copilotes LLM d'ICS.
  [Shahid & Mallavrapu, Springer CCIS 2026]
- Un agent avec accès aux automates peut causer un impact physique durable.
  [PLCBench, Zhou et al., arXiv 2026]

Conséquence : l'agent agit avec les droits d'un opérateur de confiance.

Ce qui existe déjà

Travail	Tâche	Procédé	Réseau	Graphe appris
AIRGuard (2026) – garde d'agent	oui	non	non	non
ProbGuard (2025) – moniteur de trace	partiel	partiel	non	non
SAIN (USENIX Sec. 2024) – invariants ICS	non	oui	non	non
E-GraphSAGE (2022) – IDS par graphe	non	non	oui	oui
Malladi & Thamilarasu (2026) – IDS IoT	non	non	oui	oui
Notre travail	**oui**	**oui**	**oui**	**oui**

Ce qui manque : aucun ne relie la tâche de l'agent à l'état de l'usine.

Notre idée et nos 3 contributions

L'idée

Un graphe à la passerelle relie tâche, agent, réseau, automates et étapes ; un GNN juge si la commande est « surprenante » dans ce contexte.

1. **Le problème** : définir les commandes context-shifted et en faire une tranche de test mesurable.
2. **Le modèle** : vraisemblance de la commande, conditionnée par la tâche, apprise sur données saines seules, sur le CPU de la passerelle.
3. **Un test qui peut échouer** : attaques par un agent red-team indépendant, oracle pré-enregistré, attaquant adaptatif.

Modèle de menace

Qui attaque ?

- T1 : l'agent détourné ou trompé (cause non modélisée).
- Il n'a que les 6 outils de la passerelle.
- T2 : attaquant adaptatif, boîte grise, qui doit garder l'effet physique.

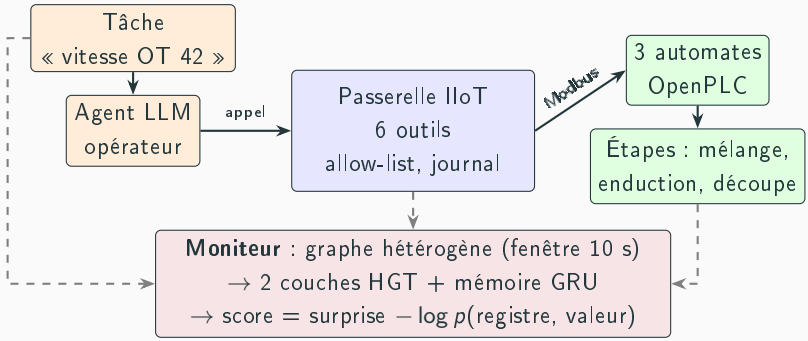
Ce qu'on protège

- Le procédé : température, tension, épaisseur.
- Le moniteur ne voit ni recettes, ni limites.

Hors périmètre

- Capteurs falsifiés, passerelle compromise, empoisonnement.

La méthode



Score calculé **avant** l'effet de la commande. Seuil : 1 % de faux positifs.

Le résultat théorique (une observation simple)

Énoncé
Un détecteur qui ne voit que (outil, registre, valeur) et l'historique de l'agent donne **le même score** à une commande context-shifted et à sa jumelle saine.

Intuition

- Les deux commandes sont identiques pour lui : il ne peut pas les séparer.
- Idem pour un IDS réseau, et pour un détecteur procédé avant l'effet.
- Le papier ne la revendique pas comme résultat : elle justifie la tranche.
- La vraie question est empirique : le GNN fait-il mieux qu'une table de valeurs par phase ?

Le plan d'expérience

- **Questions** : H1 rappel +10 points sur la tranche ; H2 la tâche compte ; H3 moins d'évasion.
- **Données** : banc BATTwin émulé, $\geq$ 8 h saines, 160 épisodes nuisibles (plafond 300).
- **Baselines** : B0 table phase-valeur, B1 allow-list, B2 XGBoost, B3 E-GraphSAGE, B4 AIRGuard, B5 juge LLM.
- **Métriques** : AUROC, AUPRC, rappel épisode à 1 % FPR, alarmes/h, latence.
- **Statistiques** : 3 graines, bootstrap, McNemar + Holm ; 155 épisodes = 80 % de puissance.

Le pilote go/no-go de Billal

- **Quoi** : 1 h de fonctionnement sain + environ 30 épisodes red-team.
- **Quand** : au plus tard le 25/10/2026.
- **Critère 1** : au moins 50 commandes context-shifted.
- **Critère 2** : un arbre de profondeur 3 (triplet + phase + type de tâche) reste sous 0,9 AUPRC.
- **Sinon** : on révise une fois le prompt red-team ; puis résultat négatif assumé.

Expérimentation à préparer par Billal

- 17/10 : choix de l'oracle (principal ou secours), sorties, limites, τ, $T_{\min}$.
- 25/10 : pilote (1 h saine, 30 épisodes) et fichiers pour l'arbre et B0.
- 28/10 – 08/11 : capture principale ($\geq$ 8 h saines, 160 épisodes nuisibles).
- 09/11 – 15/11 : entraînement GNN (3 graines), B2 XGBoost, B3 E-GraphSAGE, ablations.
- 15/11 : coût à la passerelle (4 cœurs, 4 Go) ; figure d'architecture ; DOI Zenodo.

Dates après le 25/10 : proposées, à confirmer ensemble.

Ce que prend Yulliwas (30 h, 16/10 – 15/11)

- 22/10 : enregistrement OSF (oracle, limites, hypothèses, script d'analyse).
- 26/10 : arbre et B0 sur le pilote, décision go/no-go.
- Novembre : B0 table phase-valeur, B4 AIRGuard (spécifications Modbus), B5 juge LLM figé.
- Novembre : attaquant adaptatif (générateur d'éditions, recherche gloutonne, 50 épisodes).
- Après capture : script statistique lancé sur les fichiers de scores de Billal.

Dates du 26/10 et de novembre : proposées, à confirmer ensemble.

Faiblesses connues : ce que dira un relecteur sévère

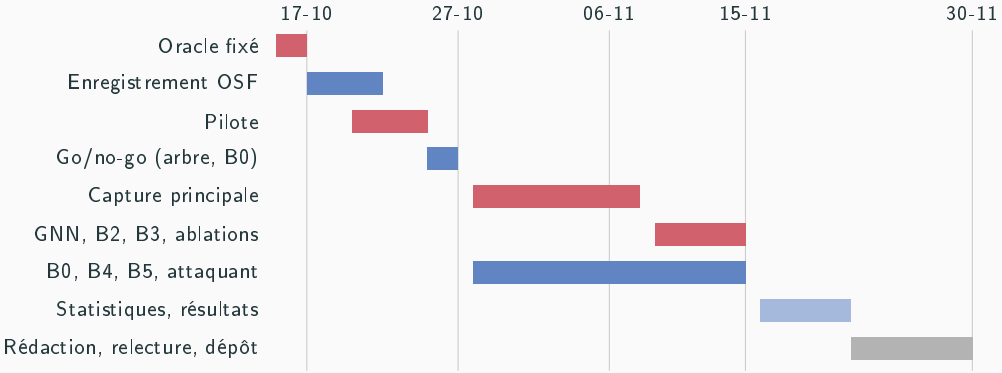
- **Validité** : données émulées, une seule cellule, attaques produites par notre propre dispositif.
- **Apport** : B2 XGBoost ou B0 peut égaler le GNN ; l'architecture est standard.
- **Oracle** : le secours (journaux) est plus sûr ; le fixer comme principal dès maintenant ?
- **Baselines** : pas de détecteur réseau récent fort (Malladi & Thamilarasu 2026).
- **Faisabilité** : calendrier serré, en parallèle du papier 13 (SoK).

Dernier relecteur aveugle : acceptation estimée à environ 27 %.

À toi de jouer, Billal

- Quelle seconde baseline réseau publique et récente ? Le code de Malladi est-il disponible ?
- Que faire si B2 égale le GNN : quel résultat de repli reste publiable ?
- Une 2e cellule ou un 2e agent : faisable avant le 30/11, sans bloquer le 13 ?
- Oracle sur journaux comme principal : qu'y perd-on, qu'y gagne-t-on ?
- Le titre te parle-t-il ? « Task-Aware » dit-il assez ce qui est nouveau ?

Calendrier jusqu'au dépôt



Rouge : Billal Bleu : Yulliwas Gris : ensemble